

Concord

The self-hostable, OSCAL-native compliance engine for CUI, defense-industrial, and federal systems.

FEDRAMP | CMMC L2 | NIST 800-53A / 800-171 | OSCAL 1.1 | 26 FRAMEWORKS | AIR-GAP CAPABLE

Compliance teams in the defense and federal space are forced to choose between cloud-only GRC tools they **cannot** put CUI into, and spreadsheets that do not scale. **Concord is the middle path** — a compliance controls platform you run inside your own security boundary. It computes a live, transparent SPRS score, generates SSPs, SARs, and **OSCAL 1.1** packages, and maps a single control effort across **26 frameworks**, so you author once and comply many. No per-seat SaaS tax, and no data leaving your perimeter.

What Concord delivers

Live CMMC L2 / SPRS scoring

A deterministic SPRS score (–203 to 110) that recomputes the moment an implementation changes — transparent and defensible, not a black box.

Guided SSP authoring

Canned, Gov-cloud-aware implementation statements with organization-defined-parameter fill-in-the-blanks — author 800-171 narratives in minutes instead of from a blank page.

Config-capture automation

Optional Microsoft Graph (M365 Government / GCC High) and AWS GovCloud connectors read live tenant configuration to auto-populate SSP parameters in support of the controls.

Compliance operations

Systems, control implementations, evidence, assessments, and POA&M and risk registers — the full ATO workflow in one governed data model.

Governance & workflow

A cross-module work queue, an alert hub with an org-wide digest, policy management with attestation, and vendor / third-party risk — with quantitative risk scoring.

Event bus & webhooks

An append-only activity stream and HMAC-signed outbound webhooks so every module — and your external systems — stay in sync.

Document & OSCAL generation

SSP, SAR, and compliance reports in xlsx, docx, csv, and json, plus OSCAL 1.1 component-definition and SSP export aligned to FedRAMP 20x / RFC-0024.

Always-current catalogs

A scheduled poller watches authoritative NIST OSCAL feeds and flags exactly which controls changed — your baseline never silently drifts out of date behind a static spreadsheet.

Cross-framework crosswalk

Approximately 121,000 mappings across 26 frameworks — FedRAMP, CMMC, 800-171, HIPAA, ISO 27001, SOC 2, CIS v8, NIST CSF and more — with full-text search.

Continuous monitoring

A ConMon engine scores control health from evidence freshness, assessment recency, and open POA&Ms, then opens tasks and alerts automatically — a living program, not a point-in-time snapshot.

Evidence intake & diagrams

A content-addressed evidence-collection API for automated collectors, plus generated authorization-boundary and control-coverage diagrams for the SSP package.

Tamper-evident audit

A hash-chained audit log, opt-in authentication and RBAC, and database-enforced multi-tenant isolation via PostgreSQL row-level security.

Deploy anywhere

Docker and PostgreSQL. A FastAPI service, browser UI, command-line interface, and documented REST API — installable in air-gapped environments.

THE PROBLEM

Industry needs Concord answers

CUI cannot go to the cloud	Most modern GRC tools are SaaS-only and off-limits for ITAR and classified DIB workloads. Concord runs inside your boundary.
OSCAL is becoming mandatory	FedRAMP 20x and RFC-0024 push machine-readable packages toward roughly September 2026. Concord already ships OSCAL export.
SPRS math is opaque	Most enterprise GRC does not compute SPRS at all. Concord shows a live, deterministic score you can defend to an assessor.
Map once, comply many	Redundant control work across frameworks is the leading GRC cost. Concord's crosswalk collapses it into a single effort.

Where Concord wins

DIFFERENTIATOR	WHY IT MATTERS
Self-hosted / air-gap capable	Serves the CUI, ITAR, and classified buyers that SaaS-only vendors structurally cannot.
Transparent live SPRS	Deterministic and recomputed on change — defensible in a C3PAO assessment.
OSCAL-native	The government-native moat, directly on the FedRAMP 20x mandate curve.
Always-current catalogs	Auto-detects NIST OSCAL revisions and pinpoints changed controls — no more stale static workbooks.
Config-capture automation	Pulls SSP parameters from live M365 Government and AWS GovCloud configuration in support of the controls.
Continuous monitoring & workflow	ConMon control-health scoring that auto-opens tasks and alerts, with policy, vendor, and an event bus — enterprise GRC depth, self-hosted.
Crosswalk depth	26 frameworks and ~121,000 mappings with full-text search — author once, comply many.
No per-seat SaaS tax	Competitors are quote-based at \$10K–\$100K+ per year; Concord is yours to run.

CONCORD · A cross-framework, cross-control compliance platform.

Target market: CUI / defense-industrial base and federal systems · Stack: FastAPI, PostgreSQL, Docker, OSCAL 1.1